FUTURE INTERNSHIP - 2026

Web Application Vulnerability Assessment Report

.....CONTENTS.....

- Introduction .....
- Tool Details .....
- Objective .....
- Observations of the Site .....
- Functional Areas Observed .....
- Vulnerabilities Identified .....
- Missing Security Headers .....
- Potential Risk .....
- Alerts Section .....
  1. SQL INJECTION .....
  2. CROSS-SITE SCRIPITING (XSS) .....
  3. CSRF ATTACK .....
  4. PARAMETER INJECTION/ URL INJECTION .....
- Analysis .....
- Conclusion .....

INTRODUCTION

In today's digital era, web applications play a critical role in business, communication, and data management. However, the increasing reliance on web technologies has also led to a rise in cyber threats and security vulnerabilities. Ensuring the security of web applications has become a top priority for organizations to protect sensitive data and maintain user trust

One of the most effective tools used for web application security testing is OWASP ZAP (Zed Attack Proxy). It is an open-source penetration testing tool developed by the OWASP community. OWASP ZAP is widely used by security professionals and beginners to identify vulnerabilities in web applications during both development and testing phases.

OWASP ZAP acts as an intercepting proxy that sits between the user's browser and the web server. It captures and analyzes HTTP and HTTPS traffic, allowing testers to inspect requests, responses, headers, cookies, and parameters. This helps in identifying security issues such as Cross-Site Request Forgery (CSRF), missing security headers, information disclosure, and potential SQL Injection vulnerabilities.

The tool provides both automated and manual testing capabilities. Automated scanning helps quickly detect common vulnerabilities, while manual exploration allows deeper analysis of application behavior. Its user-friendly interface, powerful features, and extensibility make it suitable for both beginners and advanced security analysts.

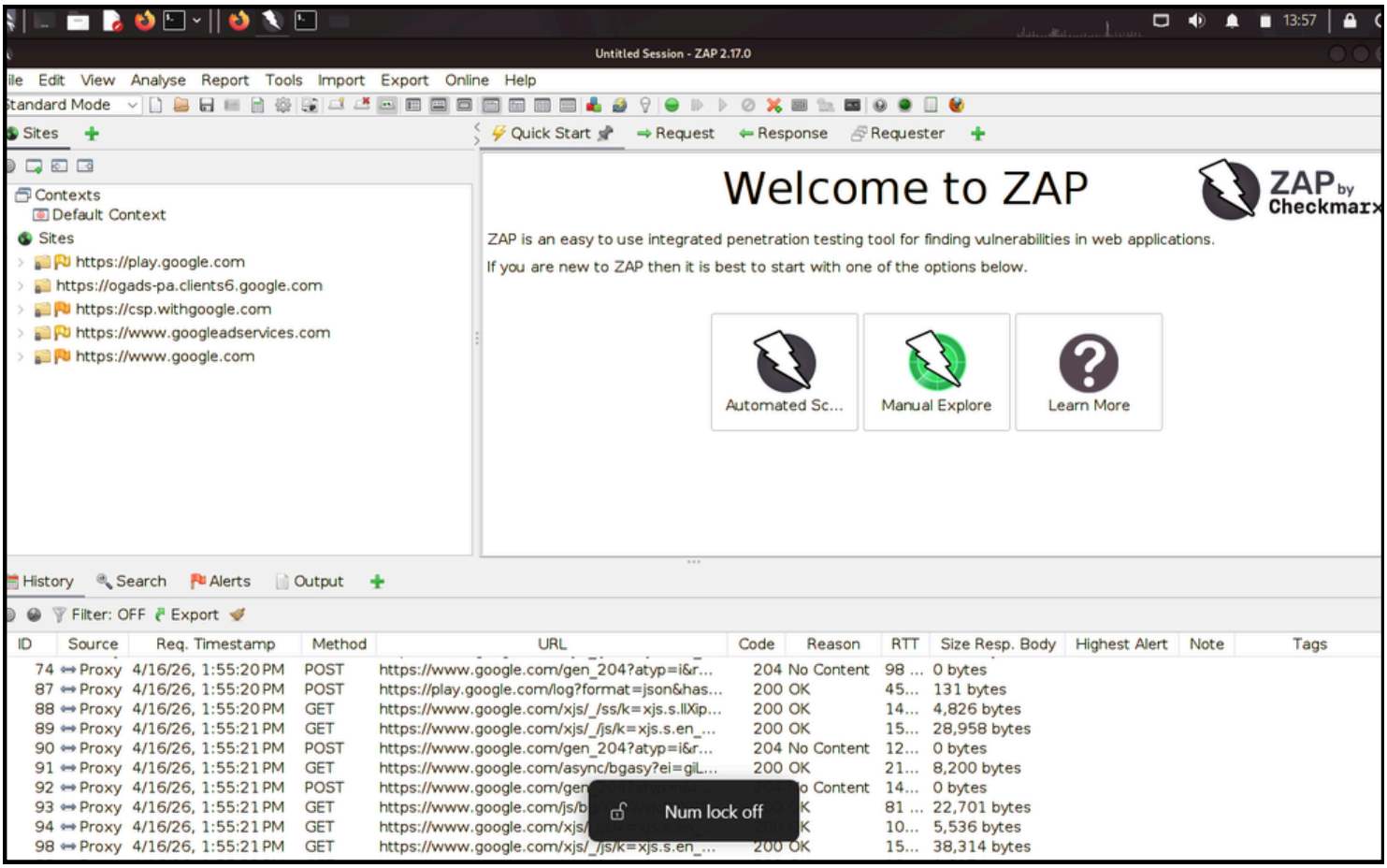
In this project, OWASP ZAP is used to perform a vulnerability assessment on a web application. The tool helps in identifying security weaknesses, analyzing application responses, and understanding how attackers may exploit these vulnerabilities. The findings from this assessment provide valuable insights into improving the overall security posture of the application.
This work also aligns with my future goal of pursuing an internship in the field of cybersecurity and ethical hacking. Gaining hands-on experience with tools like OWASP ZAP enhances my practical knowledge and prepares me for real-world security challenges. It helps me understand how to identify, analyze, and mitigate vulnerabilities effectively
.
Furthermore, this project strengthens my skills in penetration testing, vulnerability assessment, and secure coding practices. It also builds a strong foundation for my career in cybersecurity, where continuous learning and practical exposure are essential.

TOOL DETAILS

- **Tool Name: OWASP ZAP**
- **Version: 2.17.0**
- **Mode: Standard Mode**
- **Proxy: localhost:8080**
- **Scan Type: Passive Scan**

OBJECTIVE

- **To analyze the security of the target web application**
- **To identify vulnerabilities such as SQL Injection, CSRF, and misconfigurations**
- **To monitor request/response behavior**
- **To provide recommendations for securing the application**



OBSERVATION OF THE SITE

Target Identified

- http://altoro.testfire.net **(Test Web Application)**

Pages Detected

- **/index.jsp**
- **/login.jsp**
- **/search.jsp**
- **/images/inside1.jpg**

FUNCTIONAL AREAS OBSERVED

- **Login functionality**
- **Search functionality (query parameter present)**
- **Static image resources**

VULNERABILITIES IDENTIFIED

1 Absence of Anti-CSRF Tokens

- Forms do not contain CSRF protection tokens
- Attackers can perform unauthorized actions on behalf of users

2 Missing Security Headers

- Content Security Policy (CSP) not set
- X-Content-Type-Options header missing
- Anti-clickjacking protection missing

3 Information Disclosure

- Server version (Apache Coyote/1.1) exposed
- Suspicious comments found in HTML

4 SQL Injection (Potential Risk)

- The /search.jsp endpoint uses query parameters
- Input fields are not confirmed to be sanitized
- This may allow SQL Injection if backend validation is weak

ALERTS SECTION (TABLE FORMATE)

ID	ALERT NAME	RISK LEVEL	DESCRIPTION
01	Absence of Anti-CSRF Tokens	Medium	Forms lack CSRF protection
02	Content Security Policy (CSP) Header Not Set	Medium	No CSP header detected
03	Missing Anti-clickjacking Header	Medium	X-Frame-Options not set
04	Server Leaks Version Information	Low	Server details exposed
05	X-Content-Type-Options Header Missing	Low	MIME sniffing possible
06	Information Disclosure - Suspicious Comments	High	Sensitive comments found
07	Modern Web Application	High	General classification

ANALYSIS

- **The application is vulnerable to CSRF attacks due to missing tokens**
- **Security headers are not implemented, increasing exposure to broWser-based attacks**
- **Server information disclosure may help attackers plan targeted attacks**
- **Input fields (especially search) may be vulnerable to SQL Injection**
- **Overall, the application lacks basic security hardening**

CONCLUSION

The assessment using OWASP ZAP reveals multiple security weaknesses in the target web application. The absence of CSRF protection and missing security headers are critical concerns. Additionally, potential SQL Injection risks require further active testing.

Recommendation:

Immediate implementation of secure coding practices, input validation, and security headers is necessary to protect the application from attacks.